Intuit app assessment

Answer guide for Kyriq, written for Michael. Every answer says what supports it, so you can stand behind it.

OK	Answer as shown. The code or live setup supports it.
CONFIRM	Only you can answer this. It is a fact about the company, not the software.
FIX FIRST	The honest answer today is different from what the form shows, or a small fix makes a better answer true.

The questionnaire is a statement made to Intuit on the company's behalf. Where this guide and the truth differ, the truth wins. If an answer here is wrong for your situation, change it and tell us.

1. Do these first (about an hour)

1. **Clear the stored QuickBooks secrets.** All 3 QuickBooks rows in the live database still hold a client secret. The form asks whether the secret is stored securely, and the honest answer is cleaner once these are gone. Only do this after the QuickBooks client ID and secret are set in Vercel (Environment Variables), because the app reads those first. If they are not set there, clearing the rows breaks QuickBooks connect.
2. **Run one sandbox test and write down the date.** Connect a sandbox company, disconnect it, connect it again. The Authorization tab asks whether you did this. The repository has no record of a completed test.
3. **Choose one support address and use it everywhere.** The app currently shows support@chequeextractor.com (terms and 404 page), privacy@itaxhub.com and legal@itaxhub.com (privacy policy and terms), while the product is Kyriq on kyriq.com. Intuit reads these pages. Pick the real address, update the pages, and add a Help link inside the app. This also makes Error Handling question 4 a true Yes.
4. **Decide about request ID logging.** Intuit asks whether the app records the *intuit_tid* header. It does not today. It is a small code change that we can make before you answer.
5. **Decide about Kyriq Voice (beta).** It sends cheque details and QuickBooks match results to OpenAI. Either keep it off for the launch, or disclose it (see General question 6).

SQL for step 1 (Supabase SQL editor, after checking Vercel):

```
update public.integrations
   set qb_client_id = null, qb_client_secret = null, qb_redirect_uri = null
 where provider = 'quickbooks';
```

2. Only you can answer these

General 1 (complaints or investigations), General 2 (legal counsel), General 5 (sanctions, for you and every owner or affiliate), Security 1 (past security breach), Security 2 (a security team), and the number of customers you expect (App Information 4). Everything else is a fact the software can back up.

One eligibility note. The footer of the form says the Intuit App Partner Program is available to partners based in the US, UK, Australia and Canada (excluding Quebec). Confirm the company's country of registration is one of these.

3. Tab by tab

General Questions

Question	Select / enter	Why (evidence)
1. Complaints, lawsuits or investigative requests from regulators?	**CONFIRM** No	A fact about the company. Answer No only if it is true.
2. Worked with legal counsel on regulatory requirements and use of user data?	**CONFIRM** No (or Yes, if counsel has reviewed the privacy policy and terms)	The form accepts No. A Yes with a named lawyer helps the review but must be true.
3. Reviewed and will comply with the security policies?	**OK** Yes, I confirm that my app will comply...	Read the linked page first. Kyriq keeps QuickBooks tokens on the server only, uses HTTPS everywhere, signs the OAuth state, and isolates each firm's data with row-level security.
4. Designed to improve QuickBooks or facilitate a business process?	**OK** Yes	Kyriq reconciles cheques against QuickBooks transactions and clears approved ones.
5. Sanctions lists or sanctioned jurisdictions?	**CONFIRM** No	Answer for you, the owners, affiliates and anyone who benefits from the company.
6. Any generative AI functionality?	**FIX FIRST** **Yes** (currently --None--)	Cheque reading uses Google Gemini, with OpenAI as a fallback. Only cheque images are sent, never QuickBooks data. The Kyriq Voice beta uses an OpenAI model over cheque fields and QuickBooks match results; it is read-only and limited to the caller's own firm. Disclose both if a follow-up appears.

App Information

Question	Select / enter	Why (evidence)
1. Which is true about your app?	**OK** Only: built from scratch	Kyriq has its own code for OAuth and the QuickBooks calls. Do not tick the platform or credentials-for-another-platform options.
2. Platforms that make API calls	**OK** Web/SaaS and Web/Browser	The Next.js app and its Python backend are a web service. The Chrome extension runs in the browser on QuickBooks pages. Not Mobile, not Desktop.
3. How it uses Intuit data	**OK** Reads data, and writes data. Not deletes.	It reads transactions and writes back: marks a transaction cleared, corrects an amount, payee or date when the user chooses Fix, and can create a cheque entry. The code makes no delete calls to QuickBooks.
4. Private or public; how many QuickBooks customers?	**CONFIRM** Publicly available. Enter your own number.	A planning figure, not a limit. If you are unsure, use your twelve-month target for pilot firms and their clients (for example 50). Do not inflate it.
5. Which QuickBooks users can use the app?	**OK** Any user of the QuickBooks Online company (as already selected)	Whoever is allowed to approve the Intuit consent screen can connect a company; inside Kyriq, access follows the firm's own roles. Leave as selected unless the list offers an admin-only option that you prefer.
6. Integrates with platforms other than Intuit?	**OK** No	Exports to Xero, Zoho and Sage are files the user downloads, with no connection to those services. Hosting, billing and email vendors do not touch the customer's accounting data.

Authorization and Authentication

Question	Select / enter	Why (evidence)
1. Tested connect, disconnect, reconnect with a sandbox company?	**FIX FIRST** Yes, but only after you have done it once	The form already shows Yes. The repository has no record of a completed sandbox test. Do the 10-minute test in section 1, step 2, then Yes is true.
2. How often does the app refresh access tokens?	**OK** The option closest to: only when needed, just before expiry	Access tokens last one hour. Kyriq refreshes when a call needs one and the token has under 60 seconds left, then saves the new refresh token in both token tables.
3. Retry failed authorization requests?	**OK** No	One refresh attempt, no retry loop. If it fails the connection is flagged and the user is asked to reconnect. Do not tick Yes unless you add retries.
4. Ask the customer to reconnect after an auth error?	**OK** Yes	A failed refresh marks the connection 'needs reconnect' or 'revoked', the app shows Reconnect QuickBooks, and a daily check sends the reminder email.
5. Used the Intuit discovery document?	**OK** No	The OAuth addresses are written into the code. That is allowed and is the honest answer. Switching to the discovery document is a small change if Intuit asks for it.
6a. Expired access tokens	**OK** Yes	Refreshed automatically before the call.
6b. Expired refresh tokens	**OK** Yes	Intuit's reply is classified and the connection moves to Reconnect.
6c. Invalid grant errors	**OK** Yes	invalid_grant is recognised and treated as a connection that needs reconnecting.
6d. CSRF errors	**OK** Yes	The OAuth state is signed with a secret and checked when Intuit calls back; a forged or altered state is rejected.
7. Relies on the OAuth playground or offline tools for tokens?	**OK** No	Tokens come only from the app's own consent flow.

API Usage

Question	Select / enter	Why (evidence)
1. Which API categories?	**OK** Accounting API only	Everything Kyriq reads and writes is a QuickBooks accounting transaction. Do not tick Payments or Payroll, even though payroll cheques appear as accounting entries.
2. How often does the app call the APIs per customer?	**CONFIRM** Daily, Weekly and Monthly	A health check runs every morning for each connection. Reconciliation pulls happen when a user runs them, typically weekly or monthly after a statement. Drop Weekly if your firms reconcile monthly only. Do not tick Seasonally.

Error Handling

Question	Select / enter	Why (evidence)
1. Tested handling of API errors (syntax and validation)?	**OK** Yes	Real QuickBooks errors were hit and handled during development: rejected full updates are now sparse updates, empty replies are read safely, and an unsupported entity query is avoided.
2. Captures the intuit_tid response header?	**FIX FIRST** No today. Yes once the change is made.	Nothing in the code records it. Adding it to the QuickBooks request helper takes a few lines and helps Intuit support find a failed call.
3. Stores error information in logs that can be shared?	**OK** Yes	QuickBooks failures are logged on the server (Vercel and Railway logs) and sensitive actions are recorded in the audit log table.
4. Customers can contact you for support from within the app?	**FIX FIRST** No today. Yes once a Help link exists.	The only in-app addresses are on the terms and 404 pages and use an old domain. Add a Help and support link in the app, pointing at your real support address.

Security

Question	Select / enter	Why (evidence)
1. Security breach that required notification?	**CONFIRM** No	Answer No only if true.
2. A security team that regularly assesses vulnerabilities?	**CONFIRM** Yes only if a named person does this on a schedule; otherwise No	The form shows Yes. A security review was done this month (signed OAuth state, an open settings table closed, tenant isolation checked), but there is no standing team or schedule on record. Yes is defensible with a named owner and a quarterly review; if not, choose No.
3. Client ID and secret stored securely?	**FIX FIRST** Yes, after step 1 above	Production credentials belong in Vercel and Railway only. Three live database rows still hold a client secret from the sandbox era. Clear them first, then Yes is true.
4. Uses multi-factor authentication?	**OK** Yes	Authenticator-app sign-in is available to every user, with recovery codes shown once and re-issued from Settings.
5. Uses Captcha for authentication?	**OK** No	There is none.
6. Uses WebSocket?	**FIX FIRST** **Yes** (currently --None--)	The review screen listens for live match updates through Supabase Realtime, which runs over WebSocket.
7. Customer's Intuit data used by or shown to anyone else?	**OK** No	Data is visible only to users of the same firm, limited by their role, and every table is isolated by firm. Disclose the AI services under General 6 if asked.

4. After you submit

- Intuit publishes no review time. Plan for days to weeks, and answer any follow-up promptly.
- When production keys arrive, follow docs/quickbooks-production/CUTOVER.md: set the keys in Vercel and Railway, redeploy both, ask each customer to reconnect, then test one real company.
- Keep a copy of the answers you submitted. Intuit may ask about them again at the next review.